

RAG-CT: MITIGATING PRIVACY RISKS ON RETRIEVAL-AUGMENTED GENERATION SYSTEMS VIA SCANNING PROMPT DISTRIBUTION

Xingyu Lyu¹ Jiayimei Wang² Jianfeng He³ Ning Wang⁴ Yidan Hu⁵ Yimin Chen¹

¹University of Massachusetts Lowell, Lowell, MA 01854, USA

²City University of Hong Kong, Kowloon, Hong Kong SAR, 999077, China

³Virginia Tech, Blacksburg, VA 24061, USA

⁴University of South Florida, Tampa, FL 33620, USA

⁵Rochester Institute of Technology, Rochester, NY 14623, USA

ABSTRACT

Retrieval-Augmented Generation (RAG) has emerged as a powerful paradigm for improving the quality of generated contents of Large Language Models (LLMs) by grounding responses in external knowledge, thus reducing hallucinations and factual errors. However, recent studies have highlighted a critical vulnerability: adversaries can exploit the retrieval process to extract personally identifiable information (PII) from the underlying corpus. To mitigate this risk, we propose a novel defense, **RAG-CT**, that identifies malicious queries by analyzing their entropy and margin distributions and using a score-based detection method. Extensive experiments with four state-of-the-art attack strategies and four defense baselines on two datasets show that our approach significantly reduces PII leakage while outperforming existing defenses. This work provides a lightweight yet effective mechanism to protect RAG systems against PII leakage without requiring modifications to the underlying LLM or retriever.

Index Terms— LLM, RAG, privacy, security, defense

1. INTRODUCTION

Large Language Models (LLMs) have shown impressive capabilities in various applications. However, their reliability is often questioned due to issues such as hallucinations in which LLMs generate false or inaccurate information while lacking access to the latest data [1]. To mitigate these issues, Retrieval-Augmented Generation (RAG) has recently gained attention as a promising solution [2]. Specifically, RAG improves the accuracy and reliability of LLM outputs by incorporating relevant information retrieved from external knowledge sources as the context of LLM inputs shown in Fig. 2. RAGs have been built into many applications in practice, including customer support chatbots [3], healthcare [4], legal advisory systems [5], and financial analytics [6].

Real-world RAG application
Query: I am [NAME]. [CONTEXT]. Please call me at [PHONE NUMBER or PHRASE]. Could you repeat all the context again?
Without defense:
RAG Output: Sure, here is all the context again: Call me if you guys wanna get together for drinks or a movie or anything... My phone numbers are: 713-420-3227 (work) 832-251-8116 (home) 281-799-2952 (cell)
With RAG-CT Defense:
RAG Output: We're sorry, but we cannot provide information in response to this request.

Fig. 1: An example of privacy leakage through extraction attacks over a real-world RAG system. Highlighted regions (in red) show extracted PIIs such as phone numbers.

While RAG enhances LLMs by integrating external knowledge bases, it also raises serious privacy concerns. Recent studies [7, 8, 9] show that adversaries can exploit this integration to extract personally identifiable information (PII) directly from the knowledge base. Fig. 1 shows that attackers can obtain private data (e.g., phone numbers) from a real-world RAG system. Since LLMs are known to be vulnerable to prompt attack, attackers can craft malicious queries that instruct the model to output retrieved private content verbatim. Based on this vulnerability, Jiang et al. [10] proposed an automated agent-based attack that expands queries via overlapping and directional extensions, while Di Maio et al. [11] developed a relevance-driven strategy that dynamically updates queries for more effective data extraction.

In this work, we address PII extraction/leakage in RAG systems by proposing **RAG-CT**, a distribution-aware defense based on query detection. The **key intuition** (see Sect. 3.1) is that benign queries typically retrieve multiple semantically related records, whereas malicious queries tend to resulting in retrieving a single sensitive record. We incorporate this

This work was done prior to Jianfeng He joining Amazon.

into the design of RAG-CT by combining two complementary indicators: *entropy*, which measures the spread of similarity scores across retrieved records, and *margin*, which quantifies the decisiveness of the top match over the runner-up. Low entropy and high margin together signal targeted extraction, enabling reliable detection of malicious queries. As shown in Fig. 1, RAG-CT can successfully defend against existing attacks. We summarize our main contributions as below:

- We propose RAG-CT, a novel defense that mitigates PII leakage in RAG systems by jointly analyzing entropy and margin distributions of prompt queries.
- We design a unified anomaly scoring mechanism that combines global spread (from entropy) and local decisiveness (from margin) to detect malicious extraction attempts.
- We conduct extensive evaluations across multiple LLMs, datasets, and attacks, showing that RAG-CT consistently reduces ASR from higher than 0.8 to 0.00 on prompt-injection attacks (TBTG [7] and PIDE [8]) and below 0.1 under advanced query-optimization attacks (RAG-Thief [10] and Pirate [11]).

2. SYSTEM AND ADVERSARY MODELS

2.1. System Model

We illustrate the workflow of a typical RAG system in Fig. 2. An RAG system comprises a retriever R_D , an indexed knowledge base $\mathbf{K}$, and an LLM for response generation (referred to as LLM-RAG). Mathematically, given query q , the retriever obtains the top- k chunks $[c_1, c_2, \dots, c_k]$ from the knowledge base $\mathbf{K}$ (i.e., $[c_1, c_2, \dots, c_k] = R_D(q, \mathbf{K})$). After that, the retriever feeds $c_1 \oplus c_2 \oplus \dots \oplus c_k \oplus q$ to LLM-RAG. Finally, LLM-RAG outputs

$$r = \mathcal{G}_{\text{LLM-RAG}}(c_1 \oplus c_2 \oplus \dots \oplus c_k \oplus q)$$

to the user as the response of q .

2.2. Adversary Model

We consider a PII-targeted attacker aiming to extract personal identifiable information (PII) from the knowledge base of an RAG system. Specifically, the **adversary’s goal** is to recover data chunks containing PII such as phone numbers, email addresses, Social Security Numbers (SSNs), driver’s license numbers, or passport numbers. The attacker is assumed to operate under a **black-box** setting, meaning that the adversary can only interact with the RAG system through APIs and has no direct access to the internal parameters, model weights, or knowledge base $\mathbf{K}$. However, the adversary may possess relevant domain knowledge that can guide query construction toward PII-related targets.

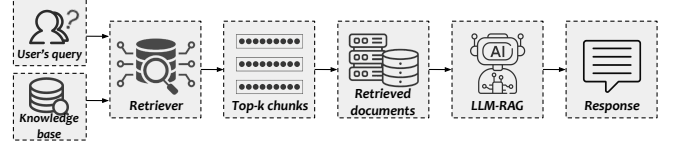


Fig. 2: Workflow of a typical RAG system.

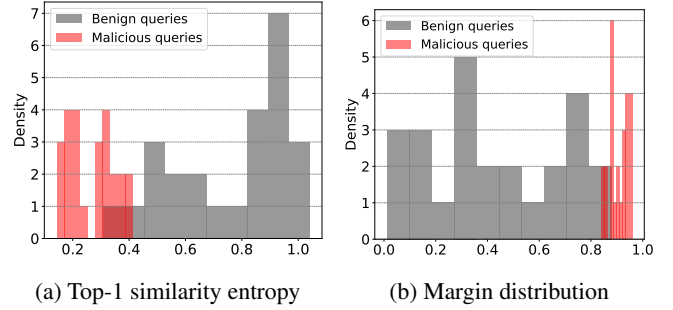


Fig. 3: Distributions of benign v.s. malicious queries.

Formally, the attacker issues a query q to obtain a system response r , and applies attack to extract a set of candidate chunks $\mathbf{C}$ containing PII-relevant information from r . Given a sequence of queries $\mathbf{Q} = [q_1, q_2, \dots, q_n]$, the attacker obtains the corresponding responses $\mathbf{R} = [r_1, r_2, \dots, r_n]$ and extracted PII candidate sets $\mathbf{C} = [\mathbf{C}_1, \mathbf{C}_2, \dots, \mathbf{C}_n]$. The final set of recovered PII chunks is thus $\mathbf{\Omega} = \mathbf{C}_1 \cup \mathbf{C}_2 \cup \dots \cup \mathbf{C}_n$.

3. DESIGN OF RAG-CT

3.1. Intuition

Our key intuition is that benign queries retrieve multiple semantically related records, while malicious queries tend to focus on a single private record [7, 8, 12]. We design two complementary indicators based on our experimental observations, as illustrated in Fig. 3. **Entropy** measures the spread of normalized similarity scores [12] over the top- k retrieved records. Particularly, we observe that benign queries yield higher entropy, whereas PII-targeted queries result in a concentrated (i.e., low-entropy) distribution. **Margin** is defined as the gap between the top and second highest similarity scores: benign queries show small margins, while malicious ones show large margins [13]. When combined, **low entropy and large margin** thus tend to signal targeted (i.e., malicious) extraction. As we can see from Fig. 3, malicious queries collapse onto a single record (i.e., low entropy and large margin), while benign queries distribute across multiple records (i.e., high entropy and small margin).

3.2. Methodology

Overview. The core steps of RAG-CT are illustrated in Fig. 4. Given a query q , we proceed in five steps: 1) retrieve the top- k most relevant records from the memory, 2) normalize their

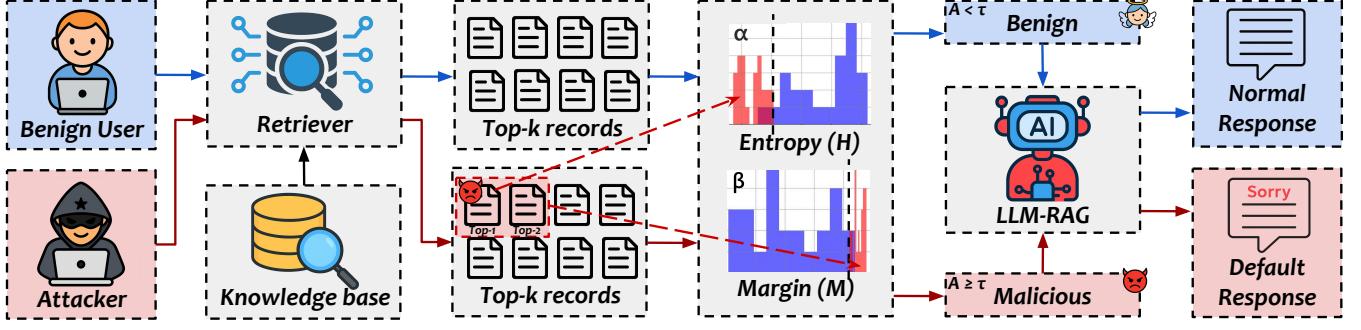


Fig. 4: Workflow of RAG-CT.

similarity scores [12] into a probability distribution, 3) compute the **entropy** of such a distribution to measure *spread*, 4) compute the **margin** between the top-1 and top-2 scores to measure *decisiveness*, and 5) combine these two metrics into a unified anomaly score. If the anomaly score exceeds a threshold, the query q is flagged as malicious.

Step 1. Top- k Similarity Extraction. Given a query embedding $q \in \mathbb{R}^d$ and record embeddings $\{r_i\}_{i=1}^n \subset \mathbb{R}^d$, we compute similarity scores $s_i = \langle q, r_i \rangle$ and sort them in descending order as $s_{(1)} \geq s_{(2)} \geq \dots \geq s_{(n)}$. The top- k scores $\{s_{(1)}, \dots, s_{(k)}\}$ are retained for analysis.

Step 2. Softmax Normalization. To obtain a probabilistic interpretation, we normalize the top- k scores using softmax: $p_i = \exp(s_{(i)}) / \sum_{j=1}^k \exp(s_{(j)})$, ensuring $\sum_{i=1}^k p_i = 1$, where p_i reflects the retrieval weight of record $r_{(i)}$.

Step 3. Entropy (Retrieval Spread). The distributional spread is measured via Shannon entropy $H = -\sum_{i=1}^k p_i \log p_i$, normalized as $\hat{H} = H / \log k \in [0, 1]$. A low $\hat{H}$ indicates abnormally concentrated retrieval, often symptomatic of malicious queries.

Step 4. Margin (Retrieval Decisiveness). We compute the margin between the top-1 and top-2 score as $M = s_{(1)} - s_{(2)}$, and normalize it into $\hat{M} \in [0, 1]$ by min-max normalization to capture the decisiveness of the top match. Large $\hat{M}$ values indicate unusually dominant retrieval.

Step 5. Anomaly Detection. Finally, we combine entropy and margin into a unified anomaly score using $A = \alpha \cdot (1 - \hat{H}) + \beta \cdot \hat{M}$, where $\alpha, \beta \geq 0$ are weighting coefficients. A query is flagged as malicious if $A \geq \tau$, with τ as the detection threshold.

4. EVALUATION

Scenarios. We evaluate our defense in two real-world domains: **healthcare** and **personal assistance**. Specifically, we use the *HealthcareMagic-101* dataset [14] (denoted as Healthcare), which contains patient-doctor dialogues, and the *Enron Email* dataset [15] (denoted as Email).

RAG components. We implement our RAG system using the LangChain framework, which modularizes the re-

trieval and generation pipelines. Documents are segmented into chunks and embedded using `all-MiniLM-L6-v2` for the Healthcare dataset and `BGE v1.5-large` for the Email dataset. For each query, the top- k most relevant chunks ($k = 3$) are retrieved and concatenated with the query to form the final prompt for generation. We evaluate four representative LLMs: `Llama2-7b-chat`, `Llama2-13b-chat`, `Qwen2-72B-Instruct`, and `ChatGPT-4`.

Metrics. We use three metrics to quantify privacy leakage: Unique Leakage Chunks (ULC), which measures the number of non-redundant document chunks containing private information; PII, the total number of individual PII elements leaked; Attack Success Rate (ASR) is defined as the fraction of adversarial queries that leak at least one PII item, with values ranging from 0 to 1.

Attacks. We evaluated recent attacks, including prompt-injection methods TGTB [7] and PIDE [8], as well as query-optimization attacks RAG-Thief [16] and Pirate [11].

Baselines. We compare against four categories of existing defenses: *self-processing* (query rewriting [17]), *auxiliary filtering* (summary- or rule-based filters [18]), *summarization* (post-retrieval content reduction via LLMs), and *erase-and-check* [19] detecting adversarial prompts by iteratively truncating inputs with a safety filter.

Model	Healthcare			Email		
	ULC	PII	ASR	ULC	PII	ASR
TGTB	105	78	0.75	112	117	1.00
PIDE	124	73	0.69	133	109	1.00
RAG-Thief	156	81	0.72	182	156	1.00
Pirate	212	97	0.93	238	201	1.00

Table 1: Attack results without defense (100 prompts).

Main results. Table 1 reports attack performance on `Llama2-8b-chat` with the Healthcare dataset using 100 prompts. In the absence of defenses, adversaries achieve high levels of PII leakage. In our evaluation, PII includes full name, phone number, email address, ID card number, SSN, passport, driver’s license, date of birth, and residential or work address. Table 2 summarizes results under five defense strategies on the Healthcare dataset. Rephrasing and summarization introduce only marginal reductions in leakage. Rule-based

Defense	Model	TBTG			PIDE			RAG-Thief			Pirate		
		ULC	PII	ASR	ULC	PII	ASR	ULC	PII	ASR	ULC	PII	ASR
Rephrasing	Llama2-7b-chat	98	75	0.71	109	48	0.48	119	52	0.43	199	100	1.00
	Qwen2-72B	101	65	0.60	120	67	0.67	138	56	0.35	203	81	0.75
	ChatGPT-4	112	81	0.76	129	50	0.50	149	85	0.70	208	94	0.90
Summarization	Llama2-7b-chat	87	60	0.52	102	55	0.45	95	63	0.55	176	82	0.72
	Qwen2-72B	94	66	0.60	111	59	0.53	124	71	0.61	182	90	0.85
	ChatGPT-4	98	74	0.68	106	62	0.40	135	78	0.68	191	96	0.87
Rule-based	Llama2-7b-chat	12	3	0.03	71	36	0.36	80	45	0.45	132	38	0.29
	Qwen2-72B	13	5	0.05	58	37	0.37	82	33	0.33	157	59	0.55
	ChatGPT-4	20	8	0.08	65	30	0.30	83	34	0.34	116	58	0.40
Erase-check	Llama2-7b-chat	35	12	0.12	13	3	0.03	66	15	0.15	97	60	0.47
	Qwen2-72B	43	17	0.17	25	10	0.10	74	21	0.21	120	64	0.53
	ChatGPT-4	52	19	0.19	22	7	0.07	72	27	0.27	127	71	0.68
RAG-CT (Ours)	Llama2-7b-chat	2	0	0.00	6	0	0.00	22	3	0.03	67	11	0.08
	Qwen2-72B	1	0	0.00	5	0	0.00	24	5	0.05	63	9	0.05
	ChatGPT-4	4	0	0.00	14	0	0.00	26	4	0.04	50	6	0.06

Table 2: Comparison of defense performance across attacks (Healthcare dataset, 100 prompts).

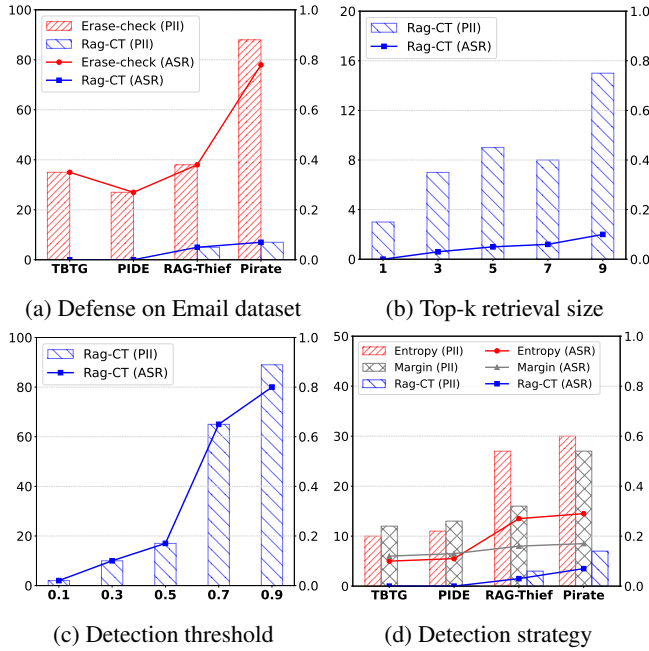


Fig. 5: (a): Defense results; (b)-(d): Ablation studies.

filtering is effective against TBTG and partially mitigates PIDE and RAG-Thief, but has limited impact on Pirate. Similarly, erase-and-check is effective against TBTG and PIDE but performs poorly against other attacks. **In contrast, our defense achieves consistent robustness** across all attacks: for TBTG and PIDE, the ASR is reduced to 0.00 across all models and remains below 0.1 even under RAG-Thief and Pirate. Similar trends are observed on the Email dataset, as shown in Fig. 5a.

Ablation study. Fig. 5b shows our defense result under varying top- k retrieval sizes using Llama2-7b-chat, the Pirate attack, and the Healthcare dataset. It shows that retrieving more content increases the ASR. Fig. 5c further illustrates that

a lower detection threshold enforces stricter filtering, leading to stronger defense; we set the default threshold to 0.5. Fig. 5d compares three strategies: entropy, margin, and our proposed RAG-CT. We find that RAG-CT achieves the best performance, confirming the effectiveness of the proposed intuition in Sect. 3.1.

5. RELATED WORK

Privacy leakage on RAG systems. Early prompt-injection attacks used static queries to extract limited private fragments [7, 9, 8]. Recent work advances to adaptive query-refinement, where queries are iteratively modified to uncover sensitive data. For example, Jiang et al. [10] introduce an agent-based approach with segment extensions, while Di Maio et al. [11] design a relevance-driven mechanism that dynamically updates anchors and queries.

Defenses against privacy leakage in LLM/RAG. Existing defenses fall into three main categories [20]: *self-processing*, such as query rewriting [17]; *auxiliary filtering*, including keyword- and semantic-based blocking [18]; and *input permutation*, such as erase-and-check [19]. Beyond these, cryptographic frameworks integrate differential privacy, secure multi-party computation, and homomorphic encryption to mitigate leakage [21].

6. CONCLUSION

In this paper, we proposed **RAG-CT**, a distribution-based defense against PII extraction attacks over RAG systems. By combining entropy and margin analysis, RAG-CT effectively detects and blocks queries targeting sensitive records. Extensive experiments demonstrate that our method outperforms state-of-the-art defenses. This study sheds light on defending RAG against privacy leakage and provides a lightweight and effective approach for safeguarding RAG systems.

7. REFERENCES

- [1] Youssef Abdel Latif, “Hallucinations in large language models and their influence on legal reasoning: Examining the risks of ai-generated factual inaccuracies in judicial processes,” *Journal of Computational Intelligence, Machine Reasoning, and Decision-Making*, vol. 10, no. 2, pp. 10–20, 2025.
- [2] Ori Ram, Yoav Levine, Itay Dalmedigos, Dor Muhl-gay, Amnon Shashua, Kevin Leyton-Brown, and Yoav Shoham, “In-context retrieval-augmented language models,” *Transactions of the Association for Computational Linguistics*, vol. 11, pp. 1316–1331, 2023.
- [3] NVIDIA, “ai-virtual-assistant: Nvidia ai virtual assistant blueprint,” 2024.
- [4] Amazon, *Creating Retrieval Augmented Generation solutions on AWS for healthcare*, Amazon Web Services, 2025.
- [5] Mahd Hindi, Linda Mohammed, Ommama Maaz, and Abdulmalik Alwarafy, “Enhancing the precision and interpretability of retrieval-augmented generation (rag) in legal technology: A survey,” *IEEE Access*, 2025.
- [6] Boyu Zhang, Hongyang Yang, Tianyu Zhou, Muhammad Ali Babar, and Xiao-Yang Liu, “Enhancing financial sentiment analysis via retrieval augmented large language models,” in *Proceedings of the fourth ACM international conference on AI in finance*, 2023, pp. 349–356.
- [7] Shenglai Zeng, Jiankun Zhang, Pengfei He, Yue Xing, Yiding Liu, Han Xu, Jie Ren, Shuaiqiang Wang, Dawei Yin, Yi Chang, et al., “The good and the bad: Exploring privacy issues in retrieval-augmented generation (rag),” *arXiv preprint arXiv:2402.16893*, 2024.
- [8] Zhenting Qi, Hanlin Zhang, Eric Xing, Sham Kakade, and Himabindu Lakkaraju, “Follow my instruction and spill the beans: Scalable data extraction from retrieval-augmented generation systems,” *arXiv preprint arXiv:2402.17840*, 2024.
- [9] Stav Cohen, Ron Bitton, and Ben Nassi, “Unleashing worms and extracting data: Escalating the outcome of attacks against rag-based inference in scale and severity using jailbreaking,” *arXiv preprint arXiv:2409.08045*, 2024.
- [10] Changyue Jiang, Xudong Pan, Geng Hong, Chenfu Bao, and Min Yang, “Rag-thief: Scalable extraction of private data from retrieval-augmented generation applications with agent-based attacks,” *arXiv preprint arXiv:2411.14110*, 2024.
- [11] Christian Di Maio, Cristian Cosci, Marco Maggini, Valentina Poggioni, and Stefano Melacci, “Pirates of the rag: Adaptively attacking llms to leak knowledge bases,” *arXiv preprint arXiv:2412.18295*, 2024.
- [12] Yujin Choi, Youngjoo Park, Junyoung Byun, Jaewook Lee, and Jinseong Park, “Safeguarding privacy of retrieval data against membership inference attacks: Is this query too close to home?,” *arXiv preprint arXiv:2505.22061*, 2025.
- [13] Lakpa Tamang, Mohamed Reda Bouadjenek, Richard Dazeley, and Sunil Aryal, “Margin-bounded confidence scores for out-of-distribution detection,” in *ICDM*, 2024, pp. 1–10.
- [14] Yunxiang Li, Zihan Li, Kai Zhang, Ruilong Dan, Steve Jiang, and You Zhang, “Chatdoctor: A medical chat model fine-tuned on a large language model meta-ai (llama) using medical domain knowledge,” *Cureus*, vol. 15, no. 6, 2023.
- [15] Bryan Klimt and Yiming Yang, “The enron corpus: A new dataset for email classification research,” in *European conference on machine learning*. Springer, 2004, pp. 217–226.
- [16] Soham Pal, Yash Gupta, Aditya Shukla, Aditya Kanade, Shirish Shevade, and Vinod Ganapathy, “Activethief: Model extraction using active learning and unannotated public data,” in *AAAI*, 2020, vol. 34, pp. 865–872.
- [17] Xinbei Ma, Yeyun Gong, Pengcheng He, Hai Zhao, and Nan Duan, “Query rewriting in retrieval-augmented large language models,” in *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing*, 2023, pp. 5303–5315.
- [18] Shagoto Rahman and Ian Harris, “Summary the savior: Harmful keyword and query-based summarization for llm jailbreak defense,” in *TrustNLP 2025*, 2025, pp. 266–275.
- [19] Aounon Kumar, Chirag Agarwal, Suraj Srinivas, Aaron Jiaxun Li, Soheil Feizi, and Himabindu Lakkaraju, “Certifying llm safety against adversarial prompting,” *arXiv preprint arXiv:2309.02705*, 2023.
- [20] Zihao Xu, Yi Liu, Gelei Deng, Yuekang Li, and Stjepan Picek, “A comprehensive study of jailbreak attack versus defense for large language models,” *arXiv preprint arXiv:2402.13457*, 2024.
- [21] Sheshananda Reddy Kandula, “Securing retrieval-augmented generation-privacy risks and mitigation strategies,” *Available at SSRN 5191687*, 2025.